

Auth API — Full Cheatsheet

Node.js + Express + MongoDB | localhost:5000 | JWT Access + Refresh Tokens

AUTH ROUTES /api/auth

POST	/api/auth/signup	Public	Body: name, email, password, confirmPassword
			Returns: User object · sends verification email
			■ Duplicate email → 409
			■ Passwords mismatch → 422
			■ Weak password → 422
GET	/api/auth/verify-email/:token	Public	Body: token in URL param (from email link)
			Returns: Success · sends welcome email
			■ Expired (24h) → 400
			■ Already verified → 400
			■ Wrong token → 400
POST	/api/auth/resend-verification	Public	Body: email
			Note: Same response whether email exists or not (prevents enumeration)
POST	/api/auth/signin	Public	Body: email, password
			Returns: accessToken (JSON) + refreshToken (httpOnly cookie)
			Note: Rate limited: 10 requests / 15 min
			■ Wrong password → 401 (remaining attempts shown)
			■ 5 fails → locked 30min → 423
			■ Unverified email → 403
			■ Deactivated account → 403
POST	/api/auth/refresh-token	Public	Body: No body — uses refreshToken cookie automatically
			Returns: New accessToken + rotated refreshToken
			■ Token reuse detected → 401 + cookie cleared
POST	/api/auth/forgot-password	Public	Body: email
			Returns: Same response whether email exists or not
			Note: Token valid 1 hour · Rate limited: 5 requests / hour
POST	/api/auth/reset-password/:token	Public	Body: password, confirmPassword
			Returns: Success message
			Note: Invalidates all refresh tokens (force re-login everywhere)
			■ Expired/invalid token → 400
GET	/api/auth/me	Private	Body: Header: Authorization: Bearer
			Returns: Full user profile
POST	/api/auth/signout	Private	Body: Header: Authorization: Bearer
			Returns: Success
			Note: Clears refreshToken from DB + clears cookie
POST	/api/auth/change-password	Private	Body: currentPassword, newPassword, confirmPassword
			Returns: Success — logs out all devices
			■ New same as old → 422
			■ Wrong current password → 401

ADMIN ROUTES /api/admin (Admin role required — all routes protected)

GET	/api/admin/users	Admin	Body: Query: ?page=1&limit=10&role=user&verified=true
			Returns: Paginated user list with total count
PATCH	/api/admin/users/:id/role	Admin	Body: role: "user" or "admin"
			Returns: Updated user

			■ Cannot change own role
PATCH	/api/admin/users/:id/status	Admin	Body: No body
			Returns: Toggles isActive true/false
			■ Cannot deactivate own account
DELETE	/api/admin/users/:id	Admin	Body: No body
			Returns: Success
			■ Cannot delete own account

COMPLETE TESTING FLOW (Step by Step)

1	POST /api/auth/signup	Send: name, email, password, confirmPassword
2	Check Mailtrap inbox	Copy token from verification link in email
3	GET /api/auth/verify-email/:token	Paste token in URL → email verified ✓
4	POST /api/auth/signin	Copy accessToken from response
5	GET /api/auth/me	Add header: Authorization: Bearer
6	Change role in MongoDB	Set role: "admin" for your user → re-signin → get new token
7	GET /api/admin/users	Use new token → admin route works ✓
8	POST /api/auth/forgot-password	Send email → check Mailtrap → copy reset token
9	POST /api/auth/reset-password/:token	Send new password → all devices logged out
10	POST /api/auth/refresh-token	No body needed (uses cookie) → get new accessToken

COMMON ERRORS & FIXES

Code	Message	Fix
422	Validation failed	Check all required fields + password strength rules
401	No token provided	Add: Authorization: Bearer in header
401	Token expired	Call POST /refresh-token → use new accessToken
401	Invalid token	Re-signin to get fresh tokens
403	Email not verified	Check Mailtrap → click verify link
403	Requires role: admin	Set role:"admin" in MongoDB → re-signin for new token
400	Invalid/expired token	Request new token (resend verification / forgot password)
409	Email already exists	Use different email or POST /signin instead
423	Account locked	Wait 30 min or use forgot password to reset
500	Server error	Check .env values + MongoDB connection string

PASSWORD RULES & SECURITY FEATURES

• Min 8 characters	Refresh Token Rotation	Every refresh = new token pair. Reuse detected = auto logout.
• At least one uppercase (A-Z)	Account Lockout	5 wrong attempts → locked for 30 minutes.
• At least one lowercase (a-z)	Email Enumeration Safe	Forgot password always returns same message.
• At least one number (0-9)	Password Change = Logout	All devices logged out when password changes.
• Special char: @ \$! % * ? & # ^	httpOnly Cookie	refreshToken not accessible via JS (XSS safe).
• Example: Sachin@123 ✓	Hashed Tokens in DB	Verify/reset tokens SHA-256 hashed before storing.